

Informe de auditoría sobre el proceso de otorgamiento y revisión de accesos

1. Objetivo del trabajo

Evaluar el diseño y la efectividad operativa de los controles del proceso de gestión de accesos a los sistemas del banco, conforme al procedimiento DOC-TEC-005 y a la política de seguridad de la información DOC-TEC-021.

2. Alcance

Se revisó el universo de altas, bajas y modificaciones de accesos ejecutadas entre el 1 de febrero y el 30 de abril de 2026 sobre los cinco sistemas clasificados como esenciales. Se tomaron muestras dirigidas sobre accesos con privilegios administrativos y sobre bajas de personal desvinculado, y se revisaron las cuatro revisiones trimestrales del período.

3. Opinión

El diseño del proceso es adecuado y responde a los requisitos de la política vigente. La efectividad operativa presenta debilidades en dos controles: la ejecución de bajas por desvinculación y la respuesta de las gerencias a la revisión trimestral.

4. Observaciones

Observación 1 — Bajas de accesos posteriores a la desvinculación (criticidad alta)

En la muestra de treinta desvinculaciones del período, siete accesos se dieron de baja entre uno y nueve días después de la fecha de desvinculación, en incumplimiento de DOC-TEC-005, sección 6, que exige la baja el mismo día. En dos de esos siete casos se registraron accesos efectivos al sistema después de la fecha de desvinculación. No se detectó actividad anómala en esos accesos, pero la ventana de exposición existió y no fue detectada por el proceso.

La causa raíz es que la notificación de Recursos Humanos a Tecnología se realiza por un canal que no genera un pendiente con vencimiento: si el mensaje no se procesa, nada lo reclama.

Observación 2 — Revisiones trimestrales sin respuesta (criticidad media)

De las cuarenta y dos gerencias alcanzadas por la revisión trimestral del primer trimestre de 2026, once no respondieron dentro del plazo y seis no respondieron en absoluto. El procedimiento prevé el escalamiento a la Gerencia General de las revisiones no respondidas, escalamiento que no se ejecutó en ninguno de los diecisiete casos. Las revisiones no respondidas se cerraron como completadas al finalizar el trimestre.

Una revisión que se cierra sin respuesta equivale a confirmar los accesos sin haberlos revisado, que es exactamente lo que el procedimiento prohíbe.

Observación 3 — Cuentas de servicio sin responsable nominal vigente (criticidad media)

Se identificaron nueve cuentas de servicio cuyo responsable nominal registrado ya no se desempeña en el banco o cambió de función. La regla de responsable nominal se incorporó tras la investigación DOC-AUD-003, pero no previó qué ocurre cuando el responsable se desvincula.

5. Aspectos satisfactorios

El control de aprobación por el propietario del dato opera correctamente: no se detectaron altas ejecutadas sin aprobación del propietario ni aprobadas por Tecnología. La expiración de accesos administrativos a los 90 días opera de forma automática y sin excepciones registradas.

6. Recomendaciones

- 1 Reemplazar la notificación de desvinculación por un pendiente con vencimiento y escalamiento automático, de modo que la falta de ejecución sea visible.
- 2 Impedir el cierre de una revisión trimestral sin respuesta de la gerencia, y ejecutar el escalamiento previsto.
- 3 Incorporar la verificación de vigencia del responsable nominal de cada cuenta de servicio a la revisión trimestral.

7. Respuesta del área auditada

Tecnología aceptó las tres recomendaciones. Respecto de la observación 2 señaló que el escalamiento depende de una funcionalidad del sistema de revisiones que no está disponible y que su desarrollo fue solicitado. Auditoría mantiene la observación: la ausencia de la funcionalidad explica la causa pero no releva del control, que puede ejecutarse manualmente mientras tanto.

8. Seguimiento

Las tres observaciones se registraron conforme a DOC-AUD-007, con responsable nominal y fecha comprometida.